COMPTIA SECURITY+ SY0-701 | DOMAIN 2 · THREATS, VULNERABILITIES, AND MITIGATIONS (22%)

Security+ 2.5 · Segmentation & Access Control

Mestre CyberSec · **Lesson 2.5 — Segmentation & Access Control** (6:06) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Isolamento network: VLAN / sub-rede / DMZ (screened subnet) — se um setor compromete, não contamina o resto. ACL (Access Control List) = o QUE pode entrar no recurso. Allowlist (default DENY — só o conhecido passa) > denylist (default ALLOW — bloqueio o conhecido). Microsegmentaç

💡 Key Exam Highlights & Critical Concepts

- DMZ: zona entre internet e rede interna — o público mora lá
- Allowlist (deny-by-default) é MAIS SEGURA que denylist
- Microsegmentação: cada carga isolada — Zero Trust aplicado

🎯 Exam Tips & Typical CompTIA Scenarios

- 'default deny, permit only known' = allowlist
- 'zone between internet and internal network' = DMZ/screened subnet

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 2.5 — Segmentation & Access Control)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Virtual Local Area Network (VLAN)

Logical segmentation of a physical network that groups devices into separate broadcast domains, regardless of physical location, to isolate traffic and reduce attack exposure.

⚠ ***Exam Trap:*** *Trigger: 'segment a network logically without new hardware' or 'separate broadcast domains' → VLAN. Do not confuse with subnetting (Layer 3); VLANs operate at Layer 2.*

• Demilitarized Zone (DMZ)

A screened subnet or perimeter network placed between an untrusted network (Internet) and a trusted internal network, hosting public-facing services like web and email servers to protect internal assets.

⚠ ***Exam Trap:*** *Trigger: 'zone between the Internet and the internal network' or 'place to put public-facing servers' → DMZ/screened subnet. CompTIA often uses 'screened subnet' as a synonym.*

• Access Control List (ACL)

A set of rules applied to network interfaces or resources that filters traffic or access based on IP, port, protocol, or user identity, defining what is allowed or denied.

⚠ ***Exam Trap:*** *Trigger: 'rules that define what traffic is permitted' or 'rule-based filtering on a router/firewall' → ACL. Know the difference: ACL = WHAT can enter; firewall often enforces broader rules including stateful inspection.*

• Allowlist (Default Deny) (N/A)

A security approach where only explicitly approved items (IPs, applications, users) are granted access, and everything else is implicitly denied by default.

⚠ ***Exam Trap:*** *Trigger: 'default deny, permit only known' or 'most secure access policy' → Allowlist. CompTIA considers allowlist MORE secure than denylist because it blocks unknown threats proactively.*

• Denylist (Default Allow) (N/A)

A security approach where everything is allowed by default and only specifically identified items are blocked, commonly used for known malicious IPs or applications.

⚠️ ***Exam Trap:*** *Trigger: 'block only known bad traffic' → Denylist. Less secure because zero-day/new threats pass through; CompTIA recommends allowlist for high-security environments.*

• Microsegmentation (N/A)

A security architecture that divides a network into very small, isolated zones (often per workload, application, or device) to apply granular security policies and limit lateral movement.

⚠️ ***Exam Trap:*** *Trigger: 'isolate each workload individually' or 'apply Zero Trust at the workload level' → Microsegmentation. Key distinction: traditional segmentation uses broad zones; microsegmentation uses tiny per-asset boundaries.*

• Zero Trust (N/A)

A security model that assumes no implicit trust for any user, device, or network location, requiring continuous verification and least-privilege access for every access request.

⚠️ ***Exam Trap:*** *Trigger: 'never trust, always verify' or 'no implicit trust based on network location' → Zero Trust. Pairs directly with microsegmentation and applies to internal AND external requests.*

• Subnet (Subnetwork) (N/A)

A logical subdivision of an IP network that separates hosts into smaller groups using subnet masks, enabling traffic isolation and efficient routing.

⚠️ ***Exam Trap:*** *Trigger: 'segment a network at Layer 3' or 'divide network using subnet masks' → Subnet. Differentiate from VLAN (Layer 2): subnetting uses IP addressing; VLANs use switch ports/tags.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Attack Surface Reduction & Disabling Unnecessary Services

🏠 **Real-World Analogy:** A house featuring twenty open windows, six exterior doors, and an unlocked skylight is nearly impossible to guard compared to a fortified building with one reinforced entrance. Server hardening is bricking up unnecessary windows, bolting the skylight, and leaving only the required entrance open. If you do not need Telnet (port 23) or FTP (port 21), shut down the daemon; a closed port cannot be exploited.

🔍 **Root Cause & Background:** Factory operating system installations enable dozens of background utilities by default to maximize consumer convenience. Every listening service represents running code susceptible to memory corruption, buffer overflows, and remote code execution vulnerabilities.

🛡️ **GRC Auditor Perspective:** Execute scheduled vulnerability port scans (Nessus/Nmap) against server subnets; cross-reference all listening ports against the organization's approved baseline port matrix.

⚠️ **How CompTIA Tests This:** Trigger: 'system administrator disables unused network services and closes unnecessary ports to minimize potential entry points'. Answer: Attack Surface Reduction / Hardening.

📌 CIS Benchmarks & Security Baselines

🏠 **Real-World Analogy:** It is like a mandatory public health inspection manual for a hospital cafeteria: it is not up to the chef's mood, but rather an authoritative 300-point checklist (freezer temperatures, sterilization times, handwashing protocols) engineered by epidemiologists to ensure safety. CIS Benchmarks serve as that rigorous consensus standard for hardening Windows, Linux, and cloud workloads.

🔍 **Root Cause & Background:** Manual system configurations introduce human errors, inconsistent security postures, and configuration drift. Standardized, peer-reviewed configuration blueprints establish defensible baselines across disparate IT assets.

🛡️ **GRC Auditor Perspective:** Audit enterprise systems using automated SCAP compliance scanners measuring adherence to CIS Benchmark Level 1 and Level 2 profiles; require formal risk acceptance sign-offs for operational deviations.

⚠️ **How CompTIA Tests This:** Trigger: 'industry-recognized, consensus-based best practice configuration guidelines used worldwide to harden operating systems, applications, and cloud environments'. Answer: CIS Benchmarks.

📌 Principle of Least Privilege (PoLP)

🏠 **Real-World Analogy:** On an ocean cruise, passengers carry keycards unlocking only their assigned cabin door. The ship engineer carries a badge accessing engine rooms, but cannot open the purser's safe. Nobody walks around holding the master key to the entire vessel. If a guest loses their card on deck, a thief can enter only one stateroom and cannot steer the ship into danger.

🔍 **Root Cause & Background:** Granting standard users administrative rights reduces IT helpdesk friction, but any malware launched by that user immediately inherits complete administrative control over the underlying operating system and network domain.

🛡️ **GRC Auditor Perspective:** Conduct periodic user access recertification reviews; strip local administrator rights from all standard business workstations; require administrative staff to log in with dedicated, non-daily privileged credentials governed by PAM vaults.

⚠️ **How CompTIA Tests This:** Trigger: 'users and processes are granted only the minimum permissions necessary to perform their required job duties'. Answer: Principle of Least Privilege (PoLP).

📌 Disabling Default Accounts & Credentials

🏠 **Real-World Analogy:** Buying an enterprise switch or surveillance camera and keeping 'admin/admin' as the login is identical to buying a newly built home and leaving the construction crew's generic temporary plastic key in the front door. Every burglar on the block knows the default factory credentials of every manufacturer by heart.

🔍 **Root Cause & Background:** Hardware vendors ship products with well-documented generic credentials to facilitate initial setup. Automated botnets continuously sweep public IP ranges attempting dictionary attacks against known default factory pairs.

🛡️ **GRC Auditor Perspective:** Establish a mandatory asset commissioning checklist requiring immediate replacement of default passwords, renaming of well-known administrative accounts, and disabling the 'Guest' account prior to production deployment.

⚠️ **How CompTIA Tests This:** Trigger: 'first step a network administrator must perform when deploying a new network appliance, router, or server'. Answer: Change default passwords / Disable default accounts.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Disabling unnecessary background network daemons and closing ports to reduce attack vectors	**Attack Surface Reduction**
Industry consensus blueprints establishing authoritative baselines for system hardening	**CIS Benchmarks**
Limiting user and software account privileges strictly to the minimum required for job roles	**Principle of Least Privilege (PoLP)**
Critical first configuration action when deploying new networking appliances or IoT hardware	**Change Default Credentials**
Replacing insecure cleartext management protocols with cryptographically protected equivalents	**Protocol Hardening (SSH/HTTPS)**
Default built-in operating system account that should remain disabled under security policy	**Guest Account (Disabled)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A company has Finance and Engineering teams connected to the same physical Layer 2 switch. The security team wants to prevent broadcast traffic and casual lateral movement between the two teams while still allowing controlled traffic through the firewall. Which segmentation approach should they implement?

A) Create separate VLANs for Finance and Engineering and route inter-VLAN traffic through the firewall.

B) Place Finance servers in a DMZ and leave Engineering on the internal LAN.

C) Use a single subnet with a denylist that blocks known attacker IP addresses.

D) Enable microsegmentation only on the Finance database server.

QUESTION 2 · EXAM SCENARIO

An organization hosts a public e-commerce web server that must receive HTTPS connections from the internet. The internal database must not be directly reachable from the internet, but the web server needs limited database access. Where should the web server be placed?

A) In an internal VLAN with the database server and a host-based firewall.

B) In a screened subnet/DMZ with firewall rules allowing HTTPS inbound and only required database traffic outbound.

C) On the guest Wi-Fi network with NAT to the database.

D) On the same subnet as employee workstations to simplify administration.

QUESTION 3 · EXAM SCENARIO

Administrators need to manage a jump server. Only two known administrator IP addresses should be allowed to initiate SSH sessions, and every other source must be rejected. Which access control approach should be configured?

A) A denylist with default allow that blocks known bad administrator IPs.

B) An allowlist with default deny that permits only the two administrator IPs.

C) A DMZ that places the jump server between two firewalls.

D) A VLAN that assigns the jump server to the database broadcast domain.

QUESTION 4 · EXAM SCENARIO

A company wants employees to browse most internet websites, but it needs to block access to a known list of phishing domains. The security team does not want to approve every legitimate website. Which filtering approach best fits this requirement?

A) Allowlist with default deny.

B) Denylist with default allow.

C) DMZ with default deny.

D) Microsegmentation with default deny.

QUESTION 5 · EXAM SCENARIO

A data center has many virtual machines on one large VLAN. After one VM is compromised, the attacker moves laterally to other VMs using allowed east-west traffic. Which control best limits this type of movement between individual workloads?

A) A single perimeter firewall at the internet edge.

B) Microsegmentation policies applied between individual workloads.

C) A DMZ that contains all internal virtual machines.

D) A denylist of known malware file hashes on the hypervisor.

QUESTION 6 · EXAM SCENARIO

A company wants internal employees to perform the same identity verification and authorization checks as remote users before accessing each internal application. Network location should no longer imply trust. Which security model should be adopted?

A) Zero Trust.

B) Screened subnet.

C) VLAN trunking.

D) Denylist-based filtering.

QUESTION 7 · EXAM SCENARIO

A network engineer needs to divide 172.16.10.0/24 into four separate IP networks for different departments. Each network must be routable and controlled by firewall rules between departments. Which concept is being used?

A) Subnetting.

B) DMZ placement.

C) Allowlisting.

D) Microsegmentation.

QUESTION 8 · EXAM SCENARIO

A router connects a public network to a web server segment. The administrator needs the router to permit TCP 443 to the web server and reject all other traffic destined for that server. What should be configured on the router?

A) An ACL applied to the relevant interface.

B) A VLAN assigned to the web server switch port.

C) A screened subnet with no firewall rules.

D) A denylist for DNS queries.

QUESTION 9 · EXAM SCENARIO

A firewall rule for an internal HR application currently permits any source to reach it and then denies a list of known malicious IP addresses. An auditor says this is too permissive. What change best aligns the rule with least privilege?

A) Replace the rule with an allowlist that permits only the HR subnet and denies all other sources.

B) Add more known malicious IP addresses to the existing deny list.

C) Move the HR application to a DMZ and allow all internal subnets.

D) Create one VLAN for all departments so the firewall rule is simpler.

QUESTION 10 · EXAM SCENARIO

Contractors use a guest Wi-Fi network and need internet access, but they must not reach internal file servers or employee subnets. Which design best enforces this requirement?

A) Place guest Wi-Fi on a separate VLAN/subnet and apply ACLs that deny access to internal address ranges.

B) Place guest Wi-Fi in the DMZ and allow all internal file server traffic.

C) Use a denylist of known contractor devices on the internal LAN.

D) Enable microsegmentation only on the internal file servers while leaving guest Wi-Fi on the internal VLAN.

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Create separate VLANs for Finance and Engineering and route inter-VLAN traffic through the firewall.

Separate VLANs create distinct Layer 2 broadcast domains on the same physical switch and can force inter-VLAN traffic through a router or firewall. A DMZ is for exposed services, a denylist does not isolate internal departments, and microsegmentation on one server does not segment the teams.

Question 2: Option B — In a screened subnet/DMZ with firewall rules allowing HTTPS inbound and only required database traffic outbound.

A screened subnet/DMZ isolates internet-facing services from the internal network. Firewall rules can permit HTTPS inbound and restrict outbound traffic to only the required database service. Internal VLAN with DB increases exposure, guest Wi-Fi is inappropriate, and workstation subnet increases lateral movement.

Question 3: Option B — An allowlist with default deny that permits only the two administrator IPs.

An allowlist with default deny permits only explicitly approved sources and rejects all others, which exactly matches the requirement. A denylist with default allow would let unknown sources attempt access unless listed as bad. DMZ and VLAN are segmentation concepts, not source-specific SSH authorization.

Question 4: Option B — Denylist with default allow.

A denylist with default allow blocks known bad domains while permitting all other traffic, which fits a broad internet browsing policy. An allowlist would require approving every allowed site. DMZ and microsegmentation are segmentation controls, not website category filtering.

Question 5: Option B — Microsegmentation policies applied between individual workloads.

Microsegmentation enforces granular, workload-level policies and can block unnecessary east-west traffic even inside the same VLAN. A perimeter firewall does not control internal VM-to-VM traffic well, a DMZ is for exposed services, and file-hash denylists do not stop network lateral movement.

Question 6: Option A — Zero Trust.

Zero Trust removes implicit trust based on network location and requires continuous verification and least-privilege authorization for each request. Screened subnets and VLANs are segmentation tools, and denylist filtering only blocks known bad items.

Question 7: Option A — Subnetting.

Subnetting divides a larger IP network into smaller logical IP networks that can be routed and filtered between each other. A DMZ is a specific screened segment for exposed services, allowlisting is an access control approach, and microsegmentation is usually workload-level policy enforcement.

Question 8: Option A — An ACL applied to the relevant interface.

An ACL is a set of permit or deny rules evaluated against traffic, often on router or firewall interfaces. It can permit TCP 443 and deny all other traffic to the server. VLANs provide Layer 2 segmentation but not detailed allow/deny rules, a screened subnet still needs rules, and DNS denylisting does not control web traffic.

Question 9: Option A — Replace the rule with an allowlist that permits only the HR subnet and denies all other sources.

The current rule uses default allow with a denylist. Least privilege requires an allowlist with default deny: only the HR subnet should be permitted, and all other sources should be denied. Adding bad IPs leaves unknown sources allowed, DMZ placement does not fix overly broad access, and a single VLAN increases exposure.

Question 10: Option A — Place guest Wi-Fi on a separate VLAN/subnet and apply ACLs that deny access to internal address ranges.

A separate guest VLAN/subnet isolates contractors at Layer 2/3, and ACLs can deny traffic to internal RFC1918 address ranges while permitting internet access. DMZ with internal access violates the requirement, a device denylist is weak, and leaving guest Wi-Fi on the internal VLAN risks lateral movement.